

true true true

Отчёт по индивидуальному проекту

этап 5

Burp Suite

ali hosseinabadi

Содержание

Цель работы

Научиться использовать Burp Suite.

Выполнение лабораторной работы

Запускаю локальный сервер DVWA:

```
(aliosseinabadi@aliosseinabadi)-[~]  
$ sudo systemctl start apache2  
  
(aliosseinabadi@aliosseinabadi)-[~]  
$ sudo systemctl start mysql  
  
(aliosseinabadi@aliosseinabadi)-[~]  
$
```

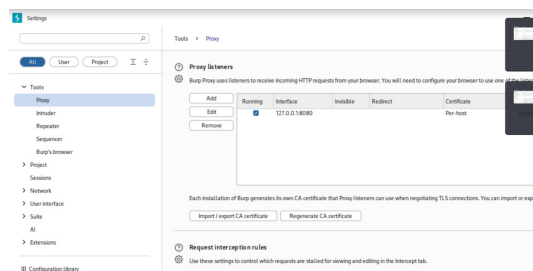
Запуск сервера

Запускаю burp suite:

```
aliosseinabadi@aliosseinabadi:~$ sudo burpsuite  
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run.java, falling back to JAVA_CMD = java  
Your JRE appears to be version 21.0.9 from Debian  
Burp has not been fully tested on this platform and you may experience problems.  
[1]
```

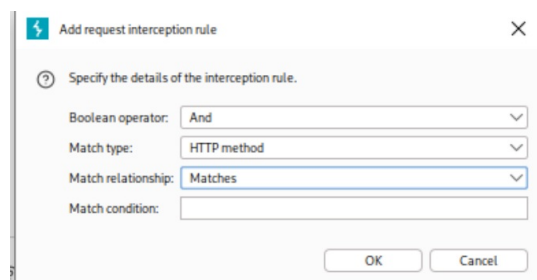
Запуск Burp suite

Я захожу в сетевые настройки браузера и настраиваю прокси-сервер так, чтобы браузер работал через Burp Suite — это позволит перехватывать данные.



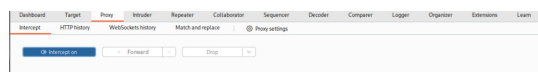
сетевые настройки сервера

В Burp Suite я меняю параметры прокси.



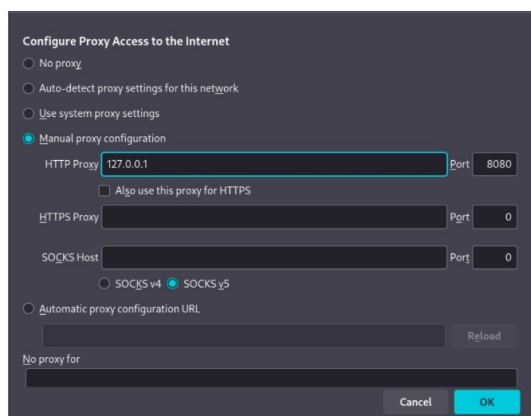
настройки проху

Включаю intercept во вкладке проху:



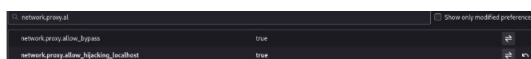
Включение intercept

Чтобы Burp Suite работал с локальным сервером, требуется изменить параметр `network_allow_hijacking_localhost` на `true`. Я выполнила эту настройку.

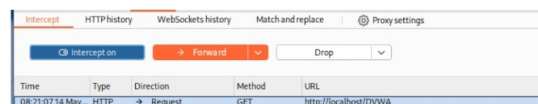


Установка параметра локального хоста

вкладка проху



вкладка проху



окно dvwa

При вводе неверных логина и пароля в запросе отображаются введённые данные. Я отправила этот запрос в Intruder (send to intruder) через вкладку Target. Во вкладке Intruder изменила тип

атаки на Cluster Bomb и данные для входа.



Username

Password

Login

Измененные данные

Target:

Positions:

```
1 POST /DVWA/login.php HTTP/1.1
2 Host: localhost
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 98
9 Origin: http://localhost
10 Connection: keep-alive
11 Referer: http://localhost/DVWA/login.php
12 Cookie: PHPSESSID=60d72622b07986b75e3ed948cfe32; security=impossible
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username=admin&password=123456&login=Login&user_token=a1d79ed85d6946d05e016d5774b297
```

Тип атака

Отметила два параметра для подбора, поэтому создала два списка со значениями для подбора в payload:

Список 1

Payloads

Payload position:

Payload type:

Payload count:

Request count:

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

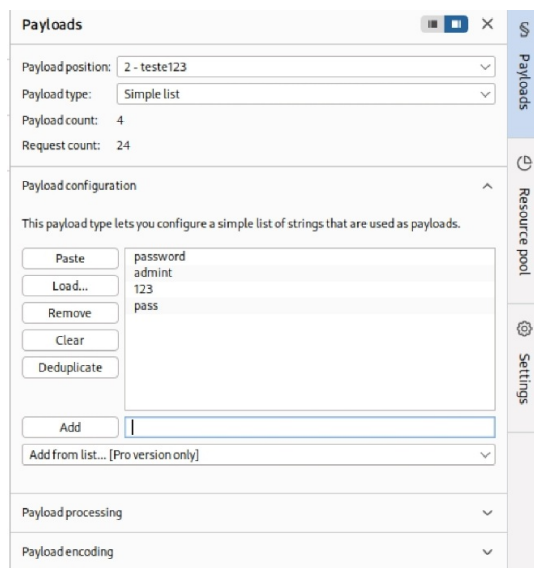
admin
password
123456
letmein
senha
1234

New desktop

+

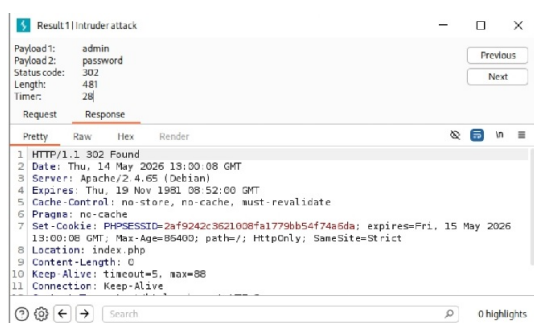
Список 2

Запускаю атаку и начинаю подбор. При открытии POST-запроса виден GET-запрос — туда перенаправило после ввода пары.



Правильная пара

В подокне Render получаю то, как выглядит полученная страница:



Полученная страница

Выводы

Научилась использовать Burp Suite.